OT Security Monitor

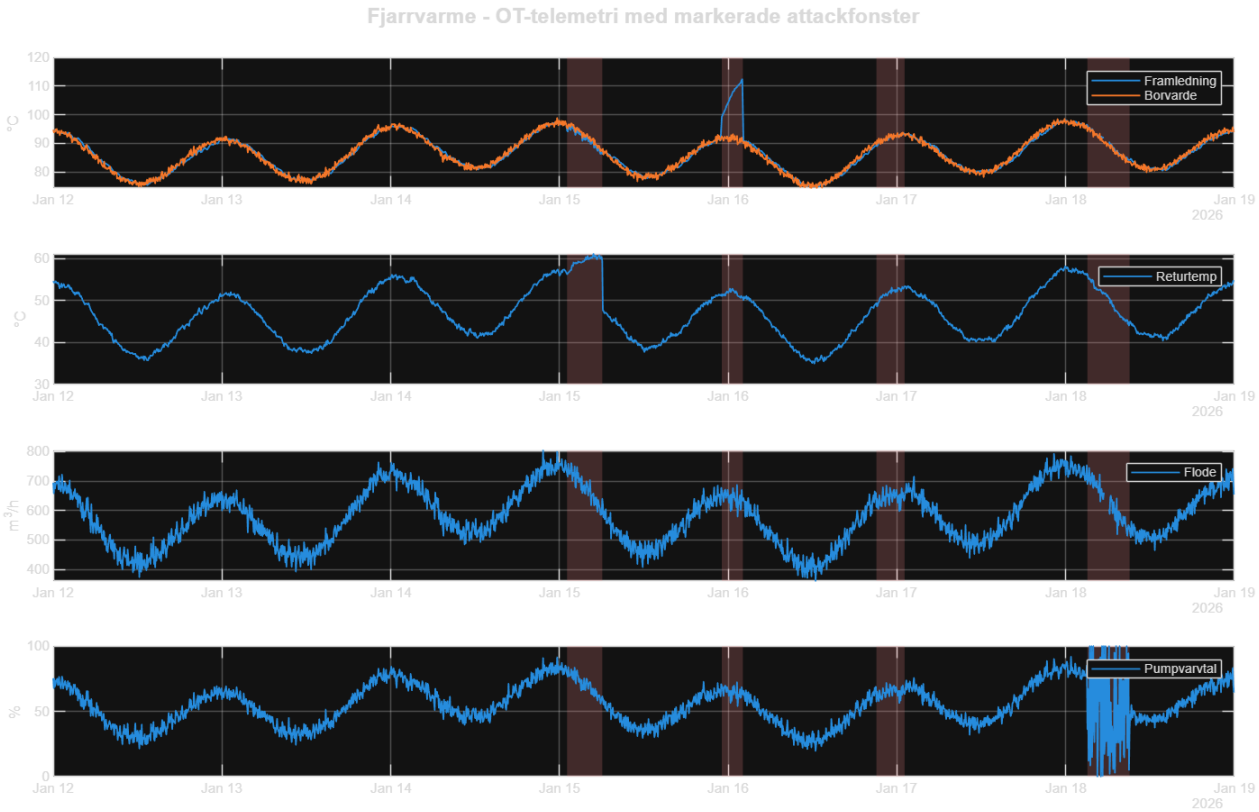
Fjärrvärme — detektion av cyberangrepp i industriella miljöer (IT/OT)

Demonstrationsprojekt för rollen Informationssäkerhetssamordnare vid ett energibolag (fjärrvärme)

Suraj Karki • MATLAB/Simulink • NIST CSF 2.0 / NIS2 / ISO 27001

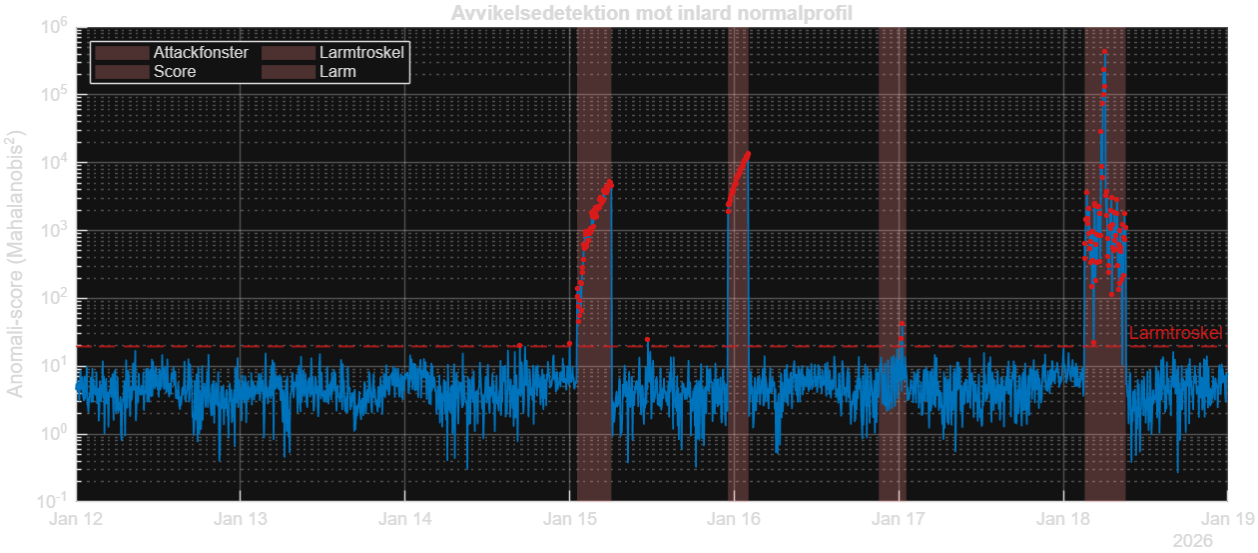
Sammanfattning. Systemet lär in normal fjärrvärmedrift från en ren baslinje och larmar därefter på avvikelser: multivariata avvikelser (Mahalanobis-avstånd), brutna fysikaliska samband (givarförfalskning) och förlorad telemetri (tillgänglighet). Fyra angreppsscenarier injiceras med facit. **Resultat:** recall 78 %, precision 98 %, F1 0,87 över 7 dygns telemetri (2016 sampel). Metodiken motsvarar strukturerad risk- och sårbarhetsanalys samt kontinuerlig övervakning enligt NIST CSF 2.0 och kraven i NIS2/cybersäkerhetslagen. Ett kompletterande UEBA-lager bevakar dessutom konfidentialitet — obehörig åtkomst till normala data (insiderhot, stulna inloggningsuppgifter, exfiltrering, privilegiemissbruk) — med recall 100 % och precision 89 %.

1. OT-telemetri och injicerade angrepp



Fyra angreppsfönster (skuggade): sensorspoofing, command injection (överhettning), replay och en ransomware-lik störning med fladdrande pump och förlorad telemetri.

2. Avvikelsedetektion



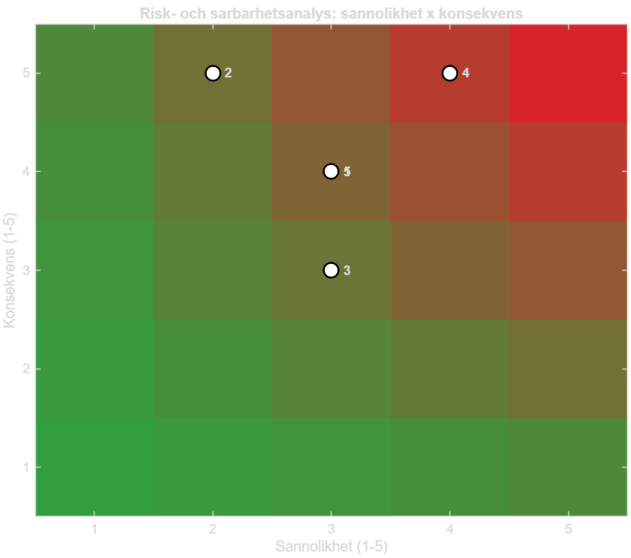
Anomali-score (Mahalanobis^2, log) mot inlärd normalprofil. Scoren ligger i baslinjebandet vid normal drift och passerar larmtröskeln (röd) i varje angreppsfönster. Detektionskvalitet: recall 78 %, precision 98 %, F1 0,87.

3. Incidenter

#	Scenario	CSF	Allvar	Detekterad
1	Sensor spoofing (false data injection)	DE.AE / PR.DS	4/5	Ja
2	Command injection (ändrat börvärde)	RS.MA / PR.AA	5/5	Ja
3	Replay attack (uppspelning av historik)	DE.CM / PR.AA	3/5	Ja
4	Ransomware-lik OT-störning	RC.RP / DE.CM	5/5	Ja

NIS2 / cybersäkerhetslagen: tidig varning inom 24 h, incidentanmälan inom 72 h och slutrapport inom en månad till MSB för väsentlig verksamhet.

4. Risk- och sårbarhetsanalys



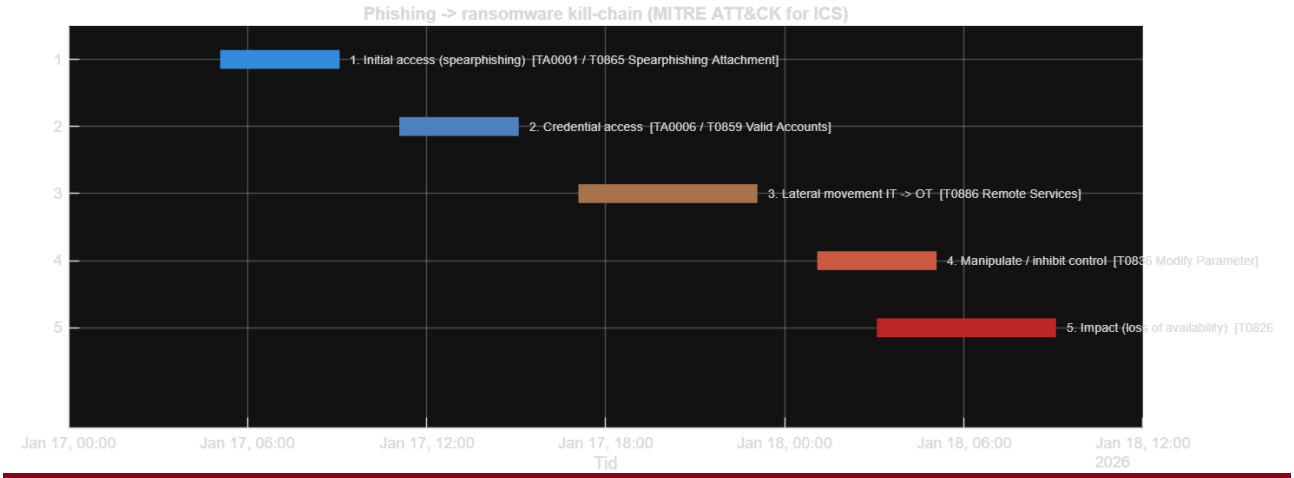
Scenario	S	K	Risk
Sensor spoofing	3	4	12
Command injection	2	5	10
Replay attack	3	3	9
Ransomware-störning	4	5	20
Leverantörskedja	3	4	12

S = sannolikhet, K = konsekvens (1–5).

5. Koppling till NIST CSF 2.0

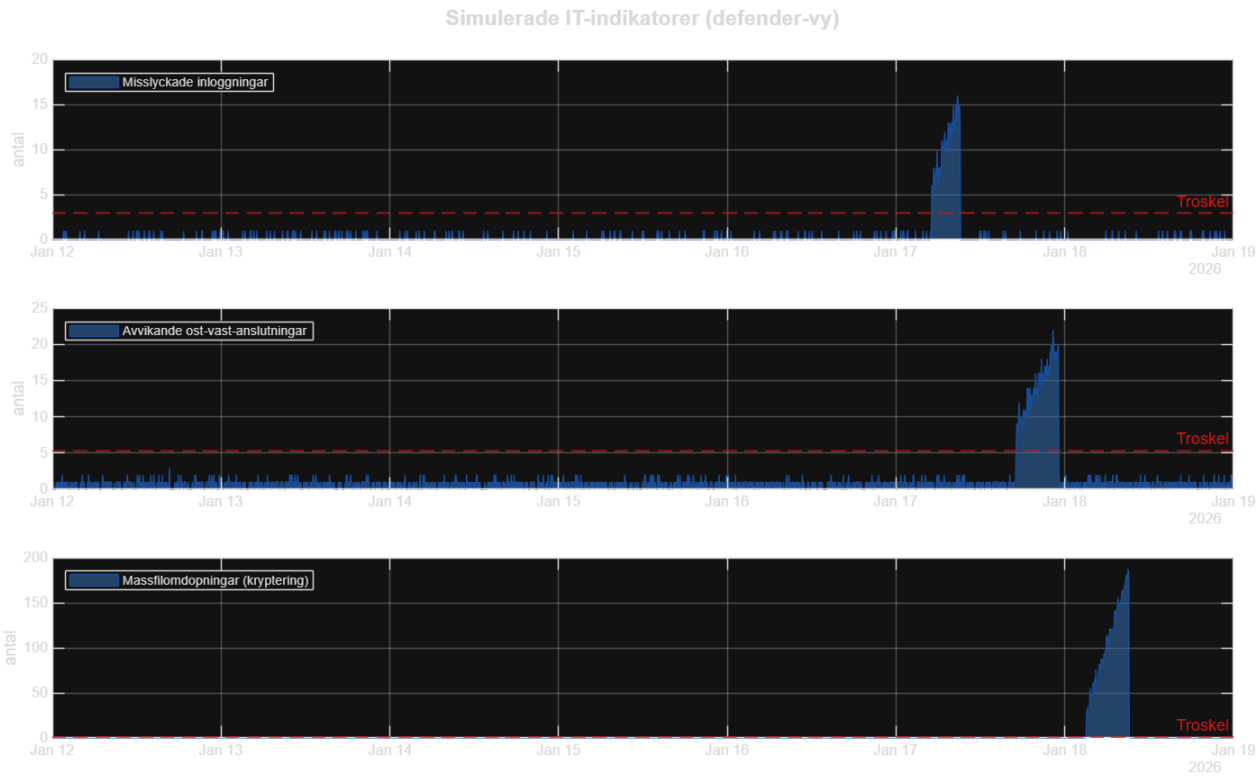
Funktion	Hur projektet adresserar den
GOVERN	Riskaptit och prioritering via risk-/sårbarhetsanalys; leverantörsrisk (GV.SC).
IDENTIFY	Tillgångs- och dataflödeskartläggning (IT/OT), riskbedömning per scenario.
PROTECT	Segmentering IT/OT, MFA, härdning av styrsystem, immutabel backup.
DETECT	Kontinuerlig övervakning och avvikelsedetektion (denna monitor).
RESPOND	Incidentklassning, allvarsgrad och NIS2-rapporteringsfrister.
RECOVER	Åtgärdsförslag och kontinuitet vid tillgänglighetsstörning.

6. Hotscenario: phishing → ransomware (MITRE ATT&CK for ICS)



Steg	ATT&CK for ICS	Försvarsåtgärd
1. Initial access (spearphishing)	T0865	Medvetenhet, e-postfiltrering, MFA
2. Credential access	T0859	MFA, least privilege, kontoövervakning
3. Lateral movement IT→OT	T0886	Segmentering, zero-trust, jump-host
4. Manipulera/inhibera styrning	T0836	Avvikelsedetektion, integritetsskydd
5. Impact (loss of availability)	T0826 / T0813	Immutabel backup, IR-plan, NIS2

7. IT-indikatorer (tidig förvarning)



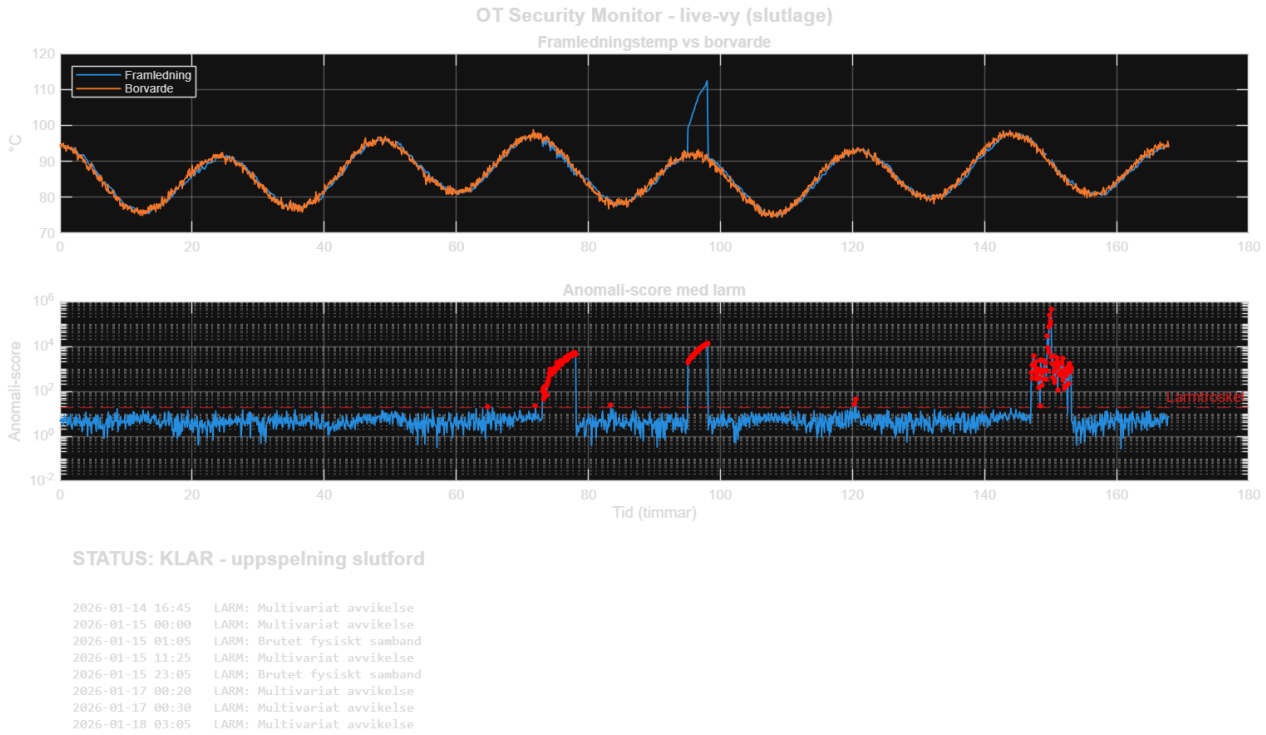
Simulerade indikatorer eskalerar i tur och ordning — misslyckade inloggningar → avvikande öst-väst-trafik → massfilomdöpningar — och passerar var sin tröskel före OT-störningen, vilket ger tid för inneslutning och rapportering.

8. Rekommenderade åtgärder (NIST ransomware-profil)

- Offline/immutabla och testade säkerhetskopior av styrsystem och historik.
- Segmentering och zero-trust mellan kontorsnät (IT) och produktionsnät (OT).
- Phishing-resistent MFA och least privilege för åtkomst till styrsystem.
- Kontinuerlig övervakning av nätverk, endpoints och givarsignaler.
- Övad incidenthanterings- och återställningsplan med out-of-band-kommunikation.

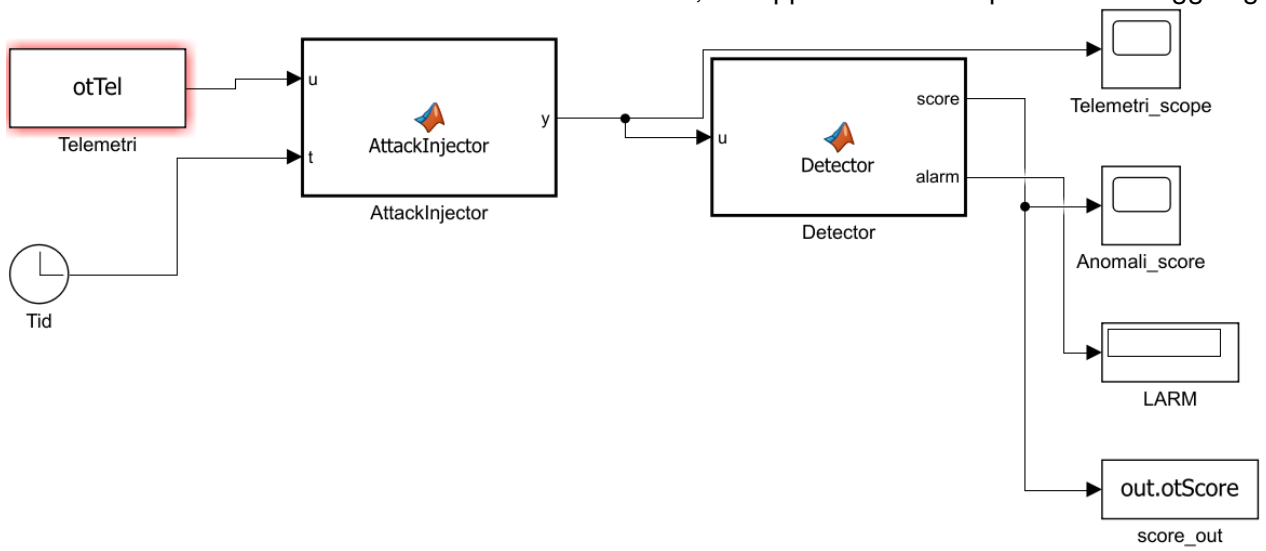
9. Live-vy: animerad uppspelning

Funktionen `ot_live` spelar upp telemetrin i realtid och larmar medan angreppen utvecklas, med en rullande händelselogg. Bilden visar slutläget med samtliga larm markerade.



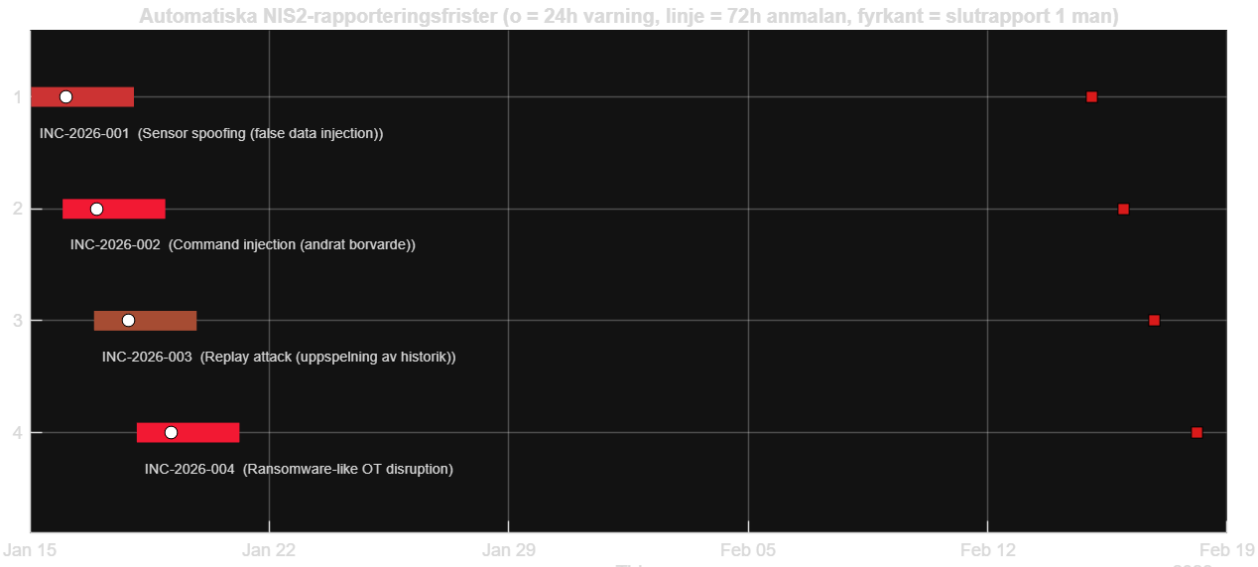
10. Simulink-demo: strömmande dataflöde med funktionsblock

Modellen `ot_security_demo` kör samma detektion som ett strömmande dataflöde: telemetrin matas in, ett **AttackInjector**-block injicerar angrepp live utifrån klockan, och ett **Detector**-block (MATLAB Function, med inlärd baslinje) beräknar anomali-score och ett **LARM**-larm, kopplat till scope och loggning.



11. Automatiserad incidentrapportering (NIS2 / GDPR / säkerhetsskydd)

Modulen `ot_autoreport` omvandlar varje detekterad incident till färdiga myndighetsanmälningar. Den klassar incidenten (typ, allvar, berörda regelverk), beräknar lagstadgade tidsfrister och fyller automatiskt i anmälningsdokument: **NIS2**/cybersäkerhetslagen (tidig varning 24 h, anmälan 72 h, slutrapport 1 månad till MSB), **GDPR** (anmälan till IMY inom 72 h vid personuppgiftsincident) och **säkerhetsskydd** (skyndsam anmälan). Utdata: ett incidentregister (CSV), ifyllda anmälningar per incident och en översiktsdashboard.

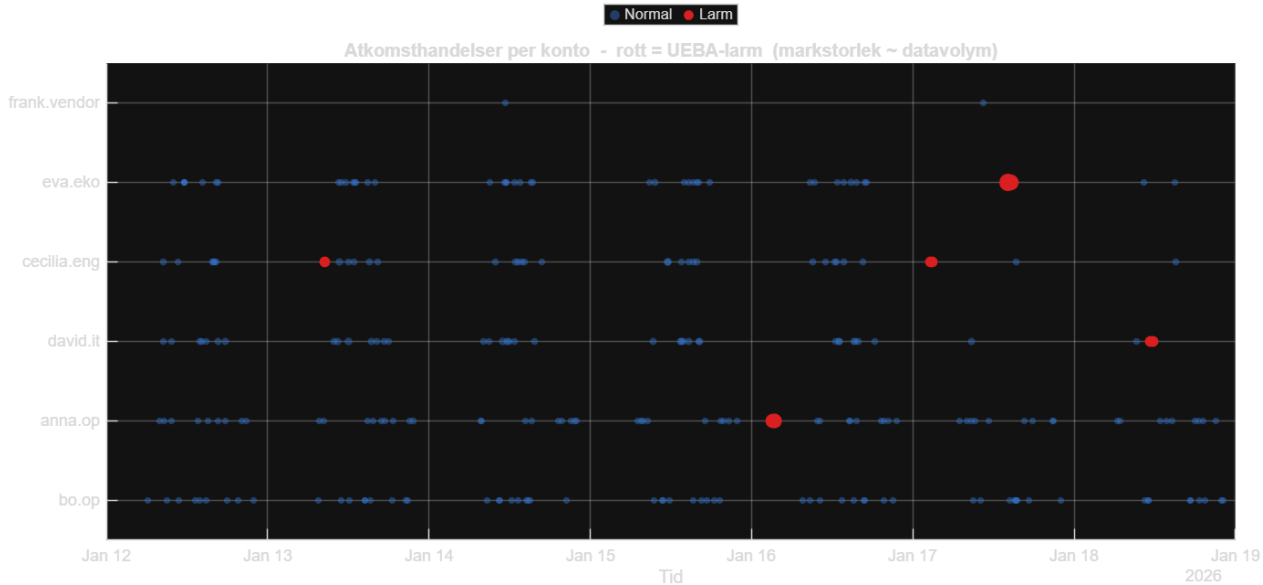


ID	Scenario	Allvar	NIS2 72h	GDPR	Säk.skydd
INC-2026-001	Sensor spoofing	4/5	2026-01-18 01:05	Nej	Nej
INC-2026-002	Command injection	5/5	2026-01-18 23:05	Nej	Ja
INC-2026-003	Replay attack	3/5	2026-01-19 21:05	Nej	Nej
INC-2026-004	Ransomware-störning	5/5	2026-01-21 03:05	Ja	Ja

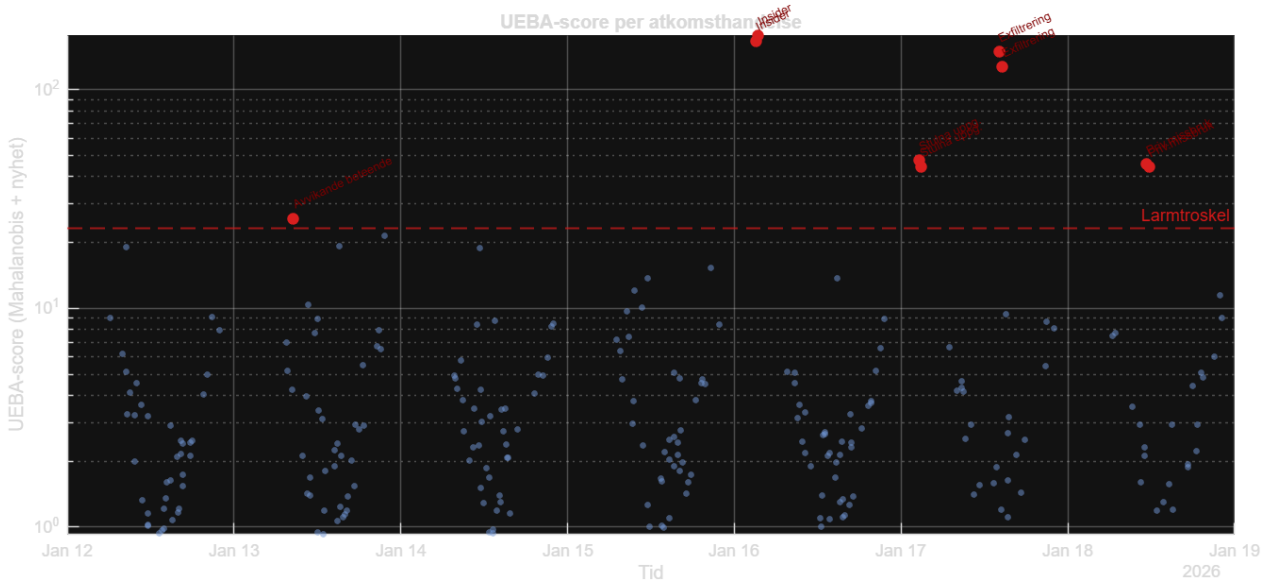
Registret skrivs även som CSV och varje rad länkar till en auto-ifylld anmälan.

12. Konfidentialitet: obehörig åtkomst och beteendeanalys (UEBA)

Avsnitten ovan upptäcker när *värdena* blir fel (integritet och tillgänglighet). Ett lika allvarligt hot är *normala värden i fel händer*: ett giltigt konto som läser, kopierar eller exfiltrerar helt normal data. Då syns ingen avvikelse i processvärdena — signalen finns i *vem* som gör *vad*, *när* och *hur mycket*. Modulen `ot_ueba` lär in varje kontos normala beteende (arbetstider, datavolym, platser och resurser) från en ren baslinje och poängsätter därefter varje åtkomst med Mahalanobis-avstånd, kompletterat med nyhetsstraff för okänd plats eller resurs utanför rollen.



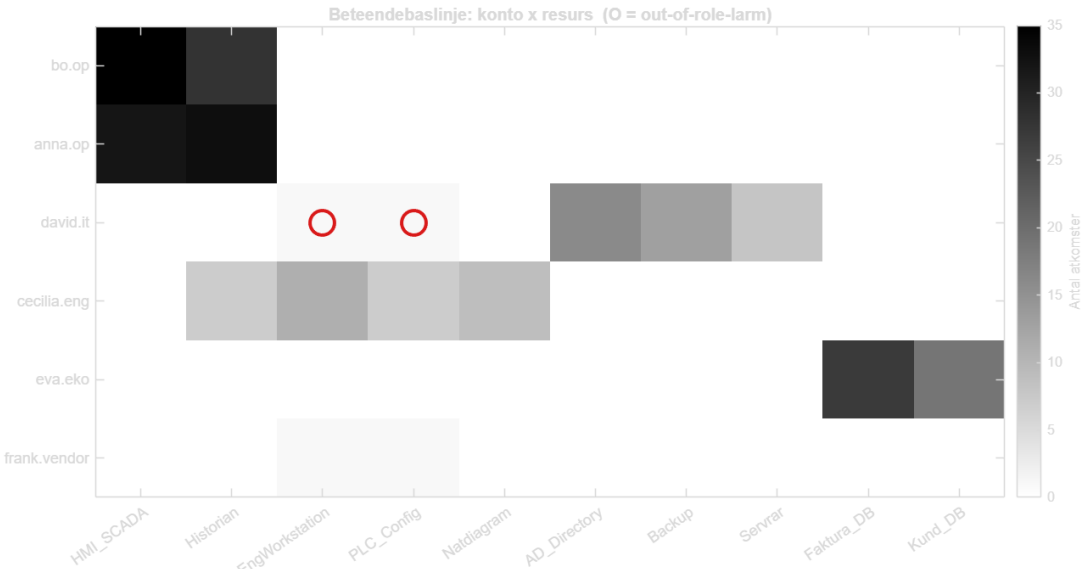
Åtkomsthändelser per konto över sju dygn (markörstorlek ∼ datavolym). Röda markörer är UEBA-larm — varje injicerat fall är en giltig inloggning med helt normala OT-värden.



UEBA-score per åtkomst (Mahalanobis + nyhet, log-skala) mot inlärd baslinje. Normal aktivitet ligger lågt; de fyra angreppstyperna passerar tydligt larmtröskeln och klassas automatiskt.

Hot	Signatur i åtkomstdata	CSF	Skydd
Insidermissbruk	Egen resurs men avvikande tid och ∼40× datavolym	DE.CM / PR.AA	Minsta behörighet, larm på massuttag
Stulna inloggn.uppg.	Giltigt konto från okänd plats vid udda tid	PR.AA / DE.CM	MFA, villkorsstyrd åtkomst
Dataexfiltrering	Export med mycket stor volym (kund-/fakturadata)	DE.CM / PR.DS	DLP, exportgränser, kryptering
Privilegiemissbruk	Konto rör system utanför sin roll (PLC/eng)	PR.AA / ID.AM	RBAC, IT/OT-separation

Resultat: 249 åtkomsthändelser, 9 larm, **recall 100 %**, **precision 89 %**, F1 0,94. Samtliga fyra incidenttyper detekterades och klassades korrekt. Det enda falsklarmet (en ovanlig men legitim konfigurationsåtgärd) gavs lägst score och klassades endast som *avvikande beteende* — precis den triagering en analytiker gör i praktiken. Värmekartan nedan visar varje kontos normala resursanvändning; de röda ringarna markerar ett IT-konto som rör OT-system (PLC och ingenjörsarbetsstation) utanför sin roll.



13. Genomförande och filer

Jag har byggt hela systemet i MATLAB och Simulink. Jag simulerade fjärrvärmedriften (framlednings- och returtemperatur, flöde, pump och tryck) utifrån utomhustemperatur och värmebehov, och injicerade fyra angreppsscenarier med känt facit. Jag tränade en normalprofil på en ren baslinjeperiod och byggde en detektor som larmar på multivariata avvikelser (Mahalanobis-avstånd), brutna fysikaliska samband (givarförfalskning) och förlorad telemetri. Jag modellerade även ett hotscenario från phishing till ransomware, kopplat till MITRE ATT&CK for ICS, med simulerade IT-indikatorer. Rapporterna genereras automatiskt ur koden: `runDemo` kör hela kedjan (simulera → injicera → detektera → figurer + rapport) och `ot_threat` skapar hotrapporten. En Simulink-modell (`ot_security_demo`) visar samma detektion som ett strömmande dataflöde med funktionsblock, och `ot_live` spelar upp förloppet live med larm och händelselogg. Ett kompletterande UEBA-lager (`ot_ueba`) bevakar konfidentialitet genom att lära in varje kontos normala beteende och larma på obehörig åtkomst till annars normala data.

Fil	Funktion
runDemo.m	Kör hela kedjan och genererar OT-rapport + hotrapport
ot_simulate.m	Simulerar fjärrvärme-telemetri (normaldrift)
ot_inject_attacks.m	Injicerar fyra angreppsscenarier med facit
ot_detect.m	Detektor: Mahalanobis + fysik-residualer + tillgänglighet
ot_report.m, ot_risk.m	Figurer, riskmodell och OT-rapport
ot_killchain.m, ot_threat.m	Kill-chain (ATT&CK for ICS), IT-indikatorer, hotrapport
ot_live.m	Live-animerad uppspelning av angrepp och detektion
ot_build_simulink.m, dh_control_loop.slx	Reglerloop (PI-regulator + värmeväxlare)
ot_build_demo.m, ot_security_demo.slx	Strömmande Simulink-demo med funktionsblock
OTSecurityMonitor.m	Interaktiv dashboard-app
runAccessDemo.m	Kör UEBA-kedjan (konfidentialitet) och genererar figurer
ot_access_sim.m, ot_access_inject.m	Simulerar åtkomstloggar och injicerar fyra konfidentialitetshot
ot_ueba.m, ot_access_report.m	Beteendebaslinje + UEBA-score, klassning och figurer

Obs: syntetisk data för demonstration. Modellen är förenklad och visar metodik och arbetssätt, inte faktiska värden från någon specifik organisation. Byggd i MATLAB/Simulink med stöd av MATLAB Agentic Toolkit.

Bilaga A. Auto-ifylld anmälan (exempel: INC-2026-004)

Genererad automatiskt av `ot_autoreport` vid detektion. Förenklad mall för demonstration — ersätter inte officiella anmälningsformulär.

1. NIS2 / cybersäkerhetslagen — tidig varning (24h) och anmälan (72h)

Verksamhet:	Energibolag AB (exempel) — Energi (fjärrvärme)
Kontakt:	Informationssäkerhetssamordnare
Incident-ID:	INC-2026-004
Upptäckt:	2026-01-18 03:05
Typ:	Ransomware-lik OT-störning (tillgänglighetsstörning)
CSF-funktion:	RC.RP / DE.CM Allvar: 5/5
Preliminär bedömning:	Misstänkt angrepp mot OT/styrsystem; påverkan på övervakning och leverans utreds.
Gränsöverskridande påverkan:	Nej (bedöms preliminärt)
Tidig varning (24h):	2026-01-19 03:05
Incidentanmälan (72h):	2026-01-21 03:05
Slutrapport (1 månad):	2026-02-18 03:05
Mottagare:	MSB

2. GDPR — personuppgiftsincident (Art. 33, anmälan inom 72h)

Dataskyddsombud:	Dataskyddsombud (DPO)
Kategorier av uppgifter:	Kunduppgifter (faktura/mätvärden) — omfattning utreds
Uppskattat antal registrerade:	Utreds
Sannolika konsekvenser:	Risk för konfidentialitetsförlust vid dataexfiltrering
Åtgärder:	Inneslutning, återställning från backup, förstärkt övervakning
Anmälan till IMY (72h):	2026-01-21 03:05

3. Säkerhetsskydd — skyndsam anmälan

Bedömning:	Händelsen kan ha betydelse för säkerhetskänslig verksamhet
Åtgärd:	Skyndsam anmälan till tillsynsmyndighet / Säkerhetspolisen